

Eng 1.1. Security Engineer Intro

Task 1: Introduction

Security engineers form the backbone of an enterprise's cyber security posture.

Task 2: What is a Security Engineer?

Why Do Organizations Need Security? Organizations can either go back to the old ways of doing business without getting any aid from modern technology, putting them at a disadvantage, or they can move forward and ensure the security of the digital side of their business.

The Role of a Security Engineer

- Owns the overall security of an organization. The main person responsible for securing an organization's digital assets.
- Ensures that the organization's cyber security risk is minimized at all times.
- Devises strategies and creates systems that minimize the risk posed by cyber security threats to an organization.
- Periodically conducts tests to ensure the robustness of the cyber security posture of an organization, identifies weak points, and prepares mitigations.
- Develops and implements secure network solutions.
- Architects and engineers trustworthy, reliable, and secure systems.
- Collaborates and coordinates with other teams to establish security protocols across the organization.

Qualifications Required for a Security Engineer An engineer takes large problems, breaks them down into smaller chunks, and then solves them. Therefore a security engineer is someone that follows this process for security problems. Overall, when hiring a security engineer, organizations look for the following basic requirements:

- 0–2 years of experience with IT administration, helpdesk, networks or security operations.

- Basic understanding of computer networks, operating systems, and programming.
- Basic understanding of security concepts such as Governance, Risk and Compliance (GRC).

Task 3: Core Responsibilities of a Security Engineer

Asset Management/Asset Inventory This will mean managing and maintaining an inventory of an organization's digital assets. Security engineers can only own an organization's security if they know what assets the organization has.

Security Policies A security engineer helps the organization create security policies based on established Security Principles. These policies are then implemented organization-wide, and the security engineer ensures that the implementation follows the letter and spirit of the policies.

Secure by Design A security engineer ensures that the organization is secure by design. The engineer understands that the security posture receives the most Return on Investment (ROI) if it follows a secure-by-design philosophy. This means that the security engineer takes steps to implement a Secure Network Architecture, ensures the organization's Windows, Linux, and Active Directory are hardened, and software development follows the Secure Software Development Lifecycle.

Security Assessment and Assurance To mitigate risks from a continuously evolving threat landscape, a security engineer plans to conduct regular security assessments, audits, and red-teaming and purple-teaming exercises to continuously improve the security posture. While security engineers might not be performing assessments and audits themselves, they are primarily involved in helping schedule these activities, creating Request for Quotations (RFQs) for external parties to perform these activities, and helping prioritize and implement the findings from them.

Q.1. Where are details about an organization's digital assets, such as name, IP address, and owner, stored?

| *answer: Asset inventory*

Q.2. Sometimes security policies can't be followed because of business needs. What avenue does a security engineer have to fulfil business needs in these

cases?

| *answer: Exceptions*

Q.3. What philosophy, if followed, provides the most Return on Investment (ROI)?

| *answer: Secure by design*

Task 4: Continuous Improvement

Ensuring Awareness A security engineer periodically runs awareness sessions targeting primarily social engineering attacks to ensure that humans don't make mistakes that can compromise an organization's security. Awareness sessions are also organized for specific teams to ensure they follow security principles related to their area of expertise, like secure software development or secure network architecture.

Managing Risks The executive management of most organizations looks at security from the lens of minimizing risks. Security is essential to businesses because ignoring it can result in operational disruptions, data leakage, lawsuits, or other forms of risk. Therefore, a security engineer is often tasked with identifying security risks, determining their likelihood and impact, and finding solutions to minimize those risks. It must be noted that eliminating all risks might not be possible when running business operations.

Change Management To ensure a robust security posture, the security engineer keeps track of changes in the organization's digital assets that can affect the security posture and takes measures to improve the security posture with the organization's evolution.

Vulnerability Management The threat landscape is continuously evolving. New software versions are released, and vulnerabilities are found in the older versions. The security engineer's job often includes monitoring vulnerabilities across the organization and planning to patch or minimize their risk.

Compliance and Audits A significant part of a security engineer's duties includes ensuring compliance with regulatory and organizational requirements. Depending on the industry, clientele, and location of the organization, it might be subject to various compliance standards such as PCI-DSS, HIPAA, SOC2, ISO27001, NIST-

800–53, and more. A security engineer works closely with both internal and external auditors to detect any non-compliance issues and effectively address them.

What is considered the weakest link in an organization's security?

| *answer: humans*

An organization's security evolves with the organization. What helps a security engineer keep the organization secure through these changes?

| *answer: Change management*

Task 5: Additional Roles and Responsibilities

Managing Security Tooling A security engineer might sometimes be required to configure or fine-tune security tools such as SIEMs, Firewalls, WAFs, EDRs, and more. In some organizations, that might also be the primary responsibility of a security engineer. In such a role, a security engineer might also be making decisions or providing input to decision-makers about tools to procure based on the organization's requirements and the engineer's assessments of competitive tools.

Tabletop Exercises Tabletop exercises are often conducted to gauge the operational readiness of an organization from a security point of view. Certain scenarios are identified to be exercised, and security team members must explain their respective roles in the scenarios under discussion.

Disaster Recovery and Crisis Management A robust security posture requires organizations to plan for untoward incidents, disasters, or crises. In any such scenario, the top priority of the executive management is to maintain business continuity. A security engineer might be involved in disaster recovery, business continuity, and crisis management planning as part of the different compliance frameworks and the organization's internal policies. The role of a security engineer in these areas might differ depending on the organization.

Q.1. What is a theoretical exercise carried out to gauge the operational readiness of an organization from a security point of view?

| *answer: Tabletop exercise*

Q.2. What is the priority of the management in case of a disaster or crisis?

| *answer: Business Continuity*

Task 6: Walking in Their Shoes

While performing their duties, security engineers must consider various aspects of running a business apart from keeping it secure. These considerations may include business operations, cost, ease of implementation, ease of use, and more. Although the most secure system is the one that is shut off and disconnected from power, such a system doesn't achieve any business objectives. Hence, a security engineer must consider business objectives and security when making decisions.

To experience what decisions a security engineer might take while performing their duties, hop on to the static site. You can do this by clicking the **View Site** button below.

What is the flag shown on the completion of the static site?

| *answer: THM{S3CUR1TY_3NG1N33R5_R0CK}*

Task 7: Conclusion

To conclude, we learned that a security engineer:

- Owns the responsibility of an organization's cyber security.
- Ensures that the systems and infrastructure of an organization are built securely.
- Helps maintain this security posture through continuous improvement and changes in the organization's digital assets.
- Takes on additional roles and responsibilities to help other teams achieve the collective goal of a secure organization.